

[← Back to Articles](#)

Security incident disclosure — July 2026

Published July 16, 2026

[Update on GitHub](#)

▲ Upvote **777**



system

system

Follow

Earlier this week, we detected and responded to an intrusion into part of our production infrastructure. This one was different from anything we had handled before in one important way: it was driven, end to end, by an autonomous AI agent system - and we detected and dissected it largely with AI of our own.

We identified unauthorized access to a limited set of internal datasets and to several credentials used by our services. We are still completing our assessment of whether any partner or customer data was affected, and we will contact any affected parties directly as required. We have found no evidence of tampering with public, user-facing models, datasets, or Spaces, and our software supply chain (container images and published packages) was verified clean.

[🔗](#) What happened

The intrusion started where AI platforms are uniquely exposed: the data-processing pipeline. A malicious dataset abused two code-execution paths in our dataset

processing (a remote-code dataset loader and a template-injection in a dataset configuration) to run code on a processing worker. From there, the actor escalated to node-level access, harvested cloud and cluster credentials, and moved laterally into several internal clusters over a weekend.

The campaign was run by an autonomous agent framework (appearing to be built on an agentic security-research harness - used LLM still not known) executing many thousands of individual actions across a swarm of short-lived sandboxes, with self-migrating command-and-control staged on public services. This matches the "agentic attacker" scenario the industry has been forecasting.

What we did

- Fixed the root vulnerability: the dataset code-execution paths used for initial access are closed.
- Eradicated the attacker's foothold across the affected clusters and rebuilt the compromised nodes.
- Revoked and rotated the affected credentials and tokens, and began a broader precautionary rotation of secrets.
- Deployed additional guardrails and stricter admission controls on our clusters.
- Improved our detection and alerting so a high-severity signal pages a responder in minutes, any day of the week.

We are working with outside cybersecurity forensic specialists to investigate the issue and review our security policies and procedures. Finally, we have also reported this incident to law enforcement agencies.

For our community

As a precaution, we recommend rotating any access tokens and reviewing recent activity on your account. If you believe you are affected, or want to report a security concern, contact us at security@huggingface.co.

We are grateful to the teams across Hugging Face who responded around the clock, and we are sorry for any disruption this caused. Security is never finished; we will keep raising the bar.

🔗 **Analyzing an AI-driven intrusion**

The attack was initially surfaced through AI-assisted detection. Our anomaly-detection pipeline uses LLM-based triage over security telemetry to separate real signals from the daily noise, and it was the correlation of those signals that flagged the compromise.

To understand what a swarm of tens of thousands of automated actions did, we ran LLM-driven analysis agents over the full attacker action log, comprised of more than 17,000 recorded events. This allowed us to reconstruct the timeline, extract indicators of compromise, map the credentials touched, and separate genuine impact from decoy activity. Thanks to this approach, we were able to do in hours what would usually take days, and match the adversary's speed.

The choice of models we could use for this analysis was constrained in a way we did not anticipate; we describe this below.

🔗 **The asymmetry problem**

When we started the log analysis, we first used frontier models behind commercial APIs. This did not work: the analysis requires submitting large volumes of real attack commands, exploit payloads, and C2 artifacts, and these requests were blocked by the providers' safety guardrails, which cannot distinguish an incident responder from an attacker. We ran the forensic analysis instead on [zai-org/GLM-](https://zai-org.com/)

5.2, an open-weight model, on our own infrastructure. This had a second benefit: no attacker data, and none of the credentials it referenced, left our environment.

This experience points to a gap worth planning for. We do not know which model powered the attacker's agents, whether a jailbroken hosted model or an unrestricted open-weight one; either way, the attacker was bound by no usage policy, while our own forensic work was blocked by the guardrails of the hosted models we first tried. The practical lesson for defenders: have a capable model you can run on your own infrastructure vetted and ready *before* an incident, both to avoid guardrail lockout and to keep attacker data and credentials from leaving your environment. This is not an argument against safety measures on hosted models, and we are sharing this feedback with the providers concerned.

What this means

Autonomous, AI-driven offensive tooling is no longer theoretical. It lowers the cost of running a broad, patient, multi-stage campaign, and it operates at machine speed. Defending an online platform now means treating the data and model surface as a first-class attack surface, and using AI on defense to keep pace. We will keep investing there, and keep sharing what we learn.

Models mentioned in this article 1

 [zai-org/GLM-5.2](#)

 Text Generation •  753B • Updated Jul 2 •  1.86M •  5.06k

Community

 [gemstonebro](#) Jul 16



Cool. How did you guys learned to do this? there is no "this is how to use LLM to protect yourself, university". I wish i knew 1/100th of what average LLM users know.

[See translation](#)

 7 replies ·  6 

 **DMQryptonic** Jul 17 

The technique is documented in articles on ArXiv and other places. This is one of the first documented instances though.

[See translation](#)

 25 

> [Expand 6 replies](#)

Reply in thread

 **Sambarboi** Jul 16 

Literally the plot of terminator 2. Glad to hear you guys were able to identify and fix the issue.

The use of GLM 5.2 is promising

[See translation](#)

 3 replies ·  23 

 **mapkob** Jul 16 

Terminator 3, but yeah.

[See translation](#)

 15 

> [Expand 2 replies](#)

Reply in thread

 **badchess** Jul 16 

Unhelpful.

 6 

 Reply

 **Tropicalbreeze** Jul 16 

It is great strategy in defence.

[See translation](#)

 2  1 

 Reply

 **leonsarmiento** Jul 16 

“ We ran the forensic analysis instead on GLM 5.2, an open-weight model, on our own infrastructure. This had a second benefit: no attacker data, and none of the credentials it referenced, left our environment.”

Hyperscalers and (X)Lab-spying-API services stock just dropped another -20%.

[See translation](#)

 1 reply ·  22 

 **caret4k3r** Jul 17 

Now we all get to wonder how exactly they are doing this with open weights/system prompt modifications.

[See translation](#)



Reply in thread

 **cappellem** Jul 17 

Is there anyway or notification feed to receive future notification of security incidents please?

[See translation](#)

 6  1 

 Reply

 **rxhunter** Jul 17 • edited Jul 17 

Thanks for sharing. Not enough people realize this is the future threat landscape. The big takeaway for me is that unless you're a Fortune 500, OpenAnthropic and ClaudeGPT probably aren't coming to save you when this happens. You guys are Huggingface, you have a few GPUs to spend when you get hacked. For the little guys and gals who might be targeted like this down the road: is Qwen 3.6 27B "enough" to analyze an attack like this usefully? Or are we flapping in the breeze if we don't have an 8xB300 server with 2+GB VRAM? Obviously a system with >2TB of VRAM is "nice to have" if you're hacked, but if you're comparatively GPU-poor is it worth building a response capability?

[See translation](#)

 6 replies ·  14  3 +

 **Jeffde** Jul 17 

You can run GLM 5.2 on 4 sparks with more than enough context to perform DFIR analysis and it does not cost a fortune.

[See translation](#)

 2 +

> [Expand 5 replies](#)

Reply in thread

 **specimba** Jul 17 

check your MCP connections too, they need second auth handshakes for correctness, otherwise your zero-GPUs will service outside.

[See translation](#)

 2 +

 Reply

80 hidden messages

[Expand all](#)

deleted 2 days ago
This comment has been hidden



deleted 2 days ago

This comment has been hidden



> [Expand 2 replies](#)

Reply in thread

deleted 2 days ago

This comment has been hidden



deleted 2 days ago

This comment has been hidden



deleted 2 days ago

This comment has been hidden



deleted 2 days ago

This comment has been hidden



> [Expand 6 replies](#)

Reply in thread

deleted 1 day ago

This comment has been hidden



deleted about 9 hours ago

This comment has been hidden (marked as Spam)



deleted about 9 hours ago

This comment has been hidden (marked as Spam)



Reply in thread

deleted about 9 hours ago

This comment has been hidden (marked as Spam)



deleted about 9 hours ago

This comment has been hidden (marked as Spam)



Edit

Preview

Start discussing this article

 Tap or paste here to upload images

 Comment

[Sign up](#) or [log in](#) to comment

 System theme

Company

TOS

Privacy

About

Careers

Website

Models

Datasets

Spaces

Pricing

Docs

